Knowledge Graph Analytics for Privacy Policy Analysis

[1,2]Mehakpreet Kaur
Department of Computer Science
[1]*Georgia Southern University*, Statesboro, USA
[2]*Mercer University*, Macon, USA
[1] mk12462@georgiasouthern.edu

Julie Allen
Department of Computer Science
[1]*Georgia Southern University*, Statesboro, USA
ja23916@georgiasouthern.edu

I. Introduction

Privacy policies attempt to articulate how organizations collect, use, store, and disclose personal information from users. These policies, however, are not written with the users' best interests. The policies are often complex, lengthy, and written in dense legal jargon which creates major obstacles to readability and understanding. Due to these challenges, users often completely avoid reading the policies. However, users still fail to comprehend the policies even if they put the time and effort into reading the policy because of vague and confusing terminology. Because of this, users do not fully comprehend and consent to the policies, and through ignorance, may actually oppose the policies. This discouraging reality has led to researchers pursuing automated techniques to understand and present the content of privacy policies in a more simplified manner. This paper seeks to review and analyze the literature that deals with the automated evaluation of privacy policies and situates our work, which develops a comparative analytics framework using knowledge graphs, to the available literature.

A. Background and Motivation

Recent studies have focused on the automated analysis of privacy policies to tackle the challenges of accessibility and actionability. Barrett et al. [1] introduced a user centric approach leveraging natural language processing and knowledge graph techniques to navigate complex legal documents, demonstrating how structured representations can extract actionable insights from dense privacy policy text. Building on this foundation, Ramasamy et al. [2] conducted an exploratory study that combined graph mining, machine learning, and NLP to reveal the inherent complexity of privacy policies, employing dimensionality reduction and visualization techniques to enhance transparency and support AI driven compliance analysis. These works establish knowledge graphs as a powerful framework for transforming unstructured privacy policies into structured, analyzable representations.

However, the complexity of privacy policies is not merely a technical challenge of information extraction; it is also a deliberate linguistic strategy. Yerby and Vaughn [3] demonstrated through legal analysis that companies intentionally employ convoluted language and ambiguous phrasing to obscure data handling practices, creating an information asymmetry that disadvantages users. They argue that the absence of regulatory standards governing readability and transparency enables this systematic obfuscation, proposing federal reforms modeled after consumer protection legislation such as the Fair Credit and Charge Card Disclosure Act. This work underscores that technical solutions for privacy policy analysis must contend not only with linguistic complexity but also with intentional strategies to limit user comprehension, reinforcing the need for comparative frameworks that can expose these practices across platforms and industries.

While these advances demonstrate the feasibility of automated privacy policy analysis, a critical gap remains: there exists no comprehensive comparative analysis of how privacy practices vary across companies, industries, and service types. Users currently lack tools to understand whether their chosen platforms provide stronger or weaker privacy protections compared to alternatives, and regulators have limited visibility into industry wide patterns and outliers. Individual policy analysis, while valuable, does not reveal the broader ecosystem of privacy practices or enable users to make informed choices based on comparative privacy protections. Furthermore, the deliberate obfuscation documented by Yerby and Vaughn [3] makes it nearly impossible for users to independently assess relative privacy protections without computational assistance.

Our approach addresses this gap by developing a knowledge graph analytics framework specifically designed for comparative privacy policy analysis across multiple platforms and sectors. We construct knowledge graphs from over X privacy policies spanning social media, e commerce, healthcare, finance, and entertainment industries, enabling systematic comparison of data collection practices, user rights, third party sharing, and transparency mechanisms. Our approach synthesizes techniques from prior work, integrating the knowledge graph construction methodology of Barrett et al. [1] with the structural analysis and clustering techniques of Ramasamy et al. [2], while addressing the deliberate obfuscation challenges identified by Yerby and Vaughn [3].

Obfuscation challenges may be complicated by the complexity of privacy laws, and in the case of certain sectors in

the United States, the patchwork nature of them. Privacy laws establish requirements for organizations on how consumer data must be managed, including its protection, secure storage, controlled sharing, proper deletion, and the rights of individuals to access, control, and delete their data. Regulations like the Health Insurance Portability and Accountability Act of 1996 (HIPPA) [4], a standard in Healthcare, The California Consumer Privacy Act (CCPA) [5], a state specific, benchmark law, and the Gramm-Leach-Bliley Act, specific to the financial sector, [6] define regulations that companies must follow. HIPPA establishes a national United States standard to protect health information, limit unauthorized use and disclosure, and grant individuals the right to obtain and correct their personal health records. [4] CCPA offers broad data privacy protection to California residents including access, control, and the right to delete their data and require businesses to disclose and protect it. The Gramm-Leach-Bliley Act requires financial institutions to protect the privacy and security of customer data. [6] These privacy regulations require that organizations disclose their privacy policy to consumers. These privacy policies are often complex, lengthy, and difficult to understand.

While this is true, our framework is designed to answer critical questions that existing approaches cannot address:

RQ1: What are Privacy Policy related connections across IT, Healthcare, and Financial Services with regulatory compliance impact and compliance violations, and how do the sectors compare?

RQ2: What are Privacy Policy related connections within the sectors of Information Technology, Healthcare, and Financial Services?

By combining structural network analysis with predictive modeling, our approach moves beyond single policy analysis to reveal industry patterns, identify best practices, detect concerning trends, and provide users with actionable comparative insights that cut through deliberately confusing language.

The remainder of this paper is organized as follows: Section 2 reviews related work in privacy policy analysis, machine learning approaches, and knowledge graph applications; Section 3 describes our dataset acquisition process; Section 4 describes our methodology for selecting articles; Section 5 presents overall trends and research gaps and describes how our project addresses these gaps.

II. Literature Review

Prior work has highlighted that privacy policies (PPs) and Terms of Service (TOS) are often intentionally written in ways that obscure data-handling practices, reducing transparency and limiting user comprehension. Yerby et al. [3] argue that organizations deliberately use complex and ambiguous language, while also noting the absence of standardized regulatory requirements for readability. They advocate for policy reforms inspired by consumer protection legislation to improve clarity and enforce transparency. However, their contribution is primarily conceptual and does not incorporate computational modeling or empirical evaluation.

Complementing this perspective, Belcheva et al. [7] conduct a longitudinal analysis of privacy policies spanning 2000 to 2019 and observe a consistent decline in readability alongside an increase in vagueness. Their study combines readability metrics, vagueness detection techniques, and a BERT-based classifier to identify linguistic trends, including a growing prevalence of reassuring language that may create a misleading sense of security. Despite its breadth, the study is constrained by its temporal coverage and dataset limitations.

A substantial body of research has instead focused on addressing the limitations of unstructured privacy policy text through structured representations such as knowledge graphs. Cui et al. [8] introduce POLIGRAPH, a knowledge graph architecture designed to overcome the limitations of sentence-level privacy policy analysis by capturing document-level structural relationships. Their POLIGRAPH-ER pipeline integrates dependency parsing, named entity recognition, and ontology-based reasoning to extract relationships between entities, data types, and purposes. The resulting graph representation achieves 97

Building on knowledge graph-based representations, further work has explored enhancing semantic modeling and interpretability. Barrett et al. [1] propose a skip-gram-enhanced knowledge graph pipeline that improves contextual relationship capture within privacy policies. Their approach supports automated summarization and risk identification, although it lacks comprehensive quantitative evaluation and is limited by dataset scale. Similarly, Chowdhury et al. [9] present GraphDPR, which integrates transformer-based language models, Sentence-BERT embeddings, and Neo4j-based graph construction to improve semantic normalization and visualization. Their framework captures both shared and company-specific privacy behaviors, though it does not yet fully support rule-based auditing or deep compliance verification.

Beyond methodological improvements, several studies examine how privacy practices vary across domains and organizational contexts. Ramasamy et al. [2] apply dimensionality reduction techniques such as t-SNE, UMAP, and PCA in combination with clustering methods including spectral clustering and HDBSCAN to analyze knowledge graphs derived from 55 Android e-commerce applications. Their findings reveal meaningful clusters representing categories such as Media & Location, Device Information, and User Activity, with the strongest separation achieved using t-SNE and spectral clustering. While effective in revealing structural patterns, the study is limited by dataset size and the absence of deeper semantic extraction beyond structural grouping.

In parallel, compliance-focused research has aimed to map privacy policies to regulatory frameworks for automated verification. Joshi et al. [10] develop a knowledge graph framework using OWL and RDF to represent regulations such as GDPR and PCI DSS, enabling structured mapping between threats, controls, and compliance requirements. Their system supports real-time violation detection and demonstrates the feasibility of converting privacy policy text into machine-processable representations, although it does not fully cover all regulatory

domains.

More recent work extends these ideas by integrating large language models with knowledge graph reasoning. Garza et al. [11] introduce PrivComp-KG, which combines knowledge graphs with retrieval-augmented generation to support compliance verification. Their system maps privacy policies to relevant regulations and achieves a reported correctness score of 0.9, enabling users to query compliance gaps effectively. However, the approach is limited to specific sections of GDPR and does not incorporate mechanisms for real-time updates to evolving legal frameworks.

III. Dataset Description

A. Dataset Source

The dataset used in this study is derived from publicly available privacy policy documents of Fortune 500 companies. These documents were collected directly from the official websites of the respective organizations, ensuring that the data reflects real-world corporate privacy disclosures. The extraction and structuring process is based on the PoliGrapher framework introduced by Cui et al. (2023) for automated privacy policy analysis.

- **Primary Source:** Official websites of Fortune 500 companies
- **Tool Reference:** PoliGraph framework (Cui et al., 2023)
- **GitHub Repository:** https://github.com/UCI-Networking-Group/PoliGraph

B. Data Acquisition Process

The dataset was constructed through a multi-step pipeline designed to convert unstructured legal text into structured, machine-readable knowledge graphs:

1) Privacy policy documents were collected from the official websites of Fortune 500 companies.
2) Each policy was downloaded and stored in PDF format.
3) The PDF files were converted into HTML format to facilitate structured text extraction.
4) The HTML documents were processed using the PoliGrapher tool, which extracts entities and relationships from the text.
5) The outputs were saved as knowledge graphs in GraphML (.graphml/.xml) format, with one file per company. One such sample knowledge graph is in Fig 1

Attempts were made to replicate the PoliGrapher pipeline; however, changes in website structures and privacy policy formats limited full reproducibility for newer documents.

C. Dataset Characteristics

The final dataset consists of knowledge graph representations for over 180 companies across multiple sectors, including Financial Services, Healthcare, and Information Technology. Each graph encodes:

- Nodes representing entities such as users, organizations, and data types

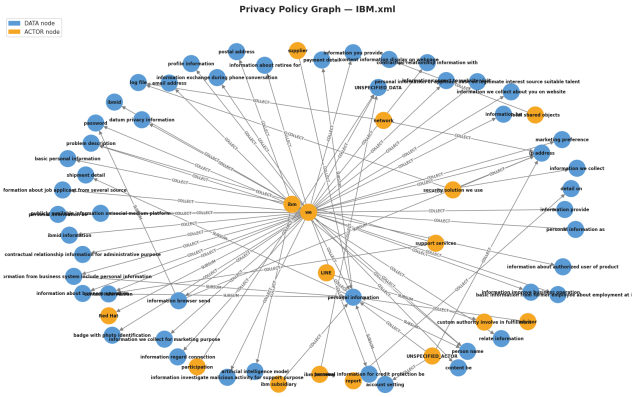

Fig. 1. Privacy Policy Knowledge Graph - IBM

- Edges representing relationships such as data collection, sharing, and usage
- Structural properties such as node count, edge density, and connectivity patterns

These graph-based features enable quantitative analysis of otherwise unstructured legal text.

D. Relevance to Research

This dataset is directly relevant to the study of privacy policy analysis and regulatory compliance. Prior research highlights the complexity and variability of privacy disclosures across organizations. By transforming policies into structured knowledge graphs, the dataset enables systematic and scalable analysis of organizational data practices.

The dataset captures key structural indicators such as third-party data sharing, diversity of actors, and relationship complexity. These features serve as proxies for evaluating transparency and compliance with major regulatory frameworks, including GDPR, HIPAA, and CCPA.

Furthermore, the dataset is well-suited for machine learning applications such as clustering, classification, and anomaly detection. These approaches enable the identification of patterns in privacy practices, detection of deviations from regulatory norms, and cross-sector comparison of compliance behaviors.

IV. Methodology

This research paper follows the methodological framework established by Munn et al. [12].

A. Search Strategy

We conducted searches across the following academic databases: Primary Sources:

- IEEE Xplore Digital Library
- ACM Digital Library
- Google Scholar (for supplementary grey literature)
- arXiv (for recent preprints, particularly 2025)

Rationale: These sources cover leading venues in security, privacy, and artificial intelligence research, including journals

(*Issues in Information Systems*, *MDPI*, *IEEE Access*), conferences (*USENIX Security Symposium*, *IEEE SoutheastCon 2025*, *AIRC 2025*), and the *IEEE Xplore* digital library. These venues publish research on privacy policy analysis, legal text processing, security technologies, and knowledge graphs.

B. Search Keywords

To capture a broad yet relevant corpus, our keyword strategy combined three central concepts: privacy policies, natural language processing, and knowledge graph or graph-based representations. Representative keyword combinations included:

- privacy policy analysis" AND NLP
- knowledge graph" AND privacy policy"
- graph mining" AND legal documents"
- automatic extraction" AND privacy terms"
- policy complexity" AND machine learning
- vague language" AND privacy policies"

C. Inclusion Criteria

Studies were included if they met all of the following criteria:

- Focus: Explicitly analyze privacy policies, terms of service, or legal disclosures using NLP, machine learning, graph mining, or knowledge graphs.
- Methodological Contribution: Present a computational framework, such as entity extraction, graph construction, complexity analysis, or automated policy comparison.
- Publication Type: Peer-reviewed journal articles, conference papers, or substantial preprints.
- Venue Quality: Published in reputable venues such as *Issues in Information Systems*, *MDPI*, *IEEE Access*, *USENIX Security Symposium*, *IEEE SoutheastCon*, *AIRC*, or available through *IEEE Xplore*.
- Language: Written in English.
- Accessibility: Full text available.

D. Exclusion Criteria

Studies were excluded if they met any of the following conditions:

- Focus solely on general knowledge graph methods with no application to privacy or legal documents.
- Analyze privacy policies without using computational, NLP, or graph-based techniques.
- Discuss legal frameworks (e.g., GDPR, CCPA) without analyzing policy text.
- Provide only abstracts, posters, or incomplete methodological descriptions.
- Duplicate versions of the same study (in such cases, the most complete version was retained).

E. Proposed Framework

To address the gaps in existing privacy policy analysis research, this study proposes a four-stage knowledge graph-based analytical framework to systematically investigate privacy policy compliance across Fortune 500 companies in the financial, healthcare, and IT sectors, as illustrated in Figure 1 2. In the first stage, individual company privacy policies are extracted and represented as GraphML structures, where the nodes encode policy clauses, data types, and entities, and edges capture semantic relationships such as data sharing, collection, consent, and transfer obligations.

In the second stage, graph-theoretic methods are applied to perform structural analysis, encompassing complexity clustering through community detection algorithms, cross-sector schema comparison to surface divergence in policy architecture, and compliance profiling to classify organizations into archetypes based on their graph signatures, addressing RQ1.

The third stage introduces a deviation and prediction layer, in which regulatory reference graphs derived from established frameworks such as the General Data Protection Regulation (GDPR), the Health Insurance Portability and Accountability Act (HIPAA), and the California Consumer Privacy Act (CCPA) serve as compliance benchmarks; graph feature classifiers are then trained to detect structural deviations and generate compliance scores per-company.

Finally, the fourth stage translates graph-level findings into interpretable outputs, including user navigation tools designed to enable non-technical stakeholders to traverse policy graphs, and actionable insights surfacing gaps in data rights, consent transparency, and user protections, thereby addressing RQ2. Collectively, this framework leverages the relational expressiveness of knowledge graphs to move beyond flat-text policy analysis, enabling structured, comparative, and predictive reasoning over privacy policy language at scale.

F. Initial Findings from Data Wrangling

Sector connections and commonalities across our dataset of 184 companies' privacy policies extracted by Poligrapher, 66 from IT, 56 from Healthcare, and 62 from Financial, reveal insights and potential areas for further investigation. The number of nodes and edges do vary by sector with a notable observation that the financial sector has the most.

¶There are many data collection commonalities between sectors such as personal information and cookie/pixel tag as the highest volume examples and identifier as the lowest common data type. However, it is also interesting to observe the differences this visualization reveals across sectors. For example, all IT companies in our data reference personal information, while some healthcare organizations do not. Observing what's unique to each sector provides insights into data types that might be uniquely affected by regulations or perhaps unique considerations that impact the different sectors.

V. Conclusion

The reviewed literature reveals three major trends in privacy policy analysis. First, there is a clear shift from sentence-level analysis to document-level structural understanding, exemplified by POLIGRAPH's knowledge graph approach and GraphDPR [8] [10] [9]. Second, researchers increasingly recognize that privacy policy complexity is not merely a technical challenge but often a deliberate obfuscation strategy [3] [7]. Third, there is growing emphasis on visualization

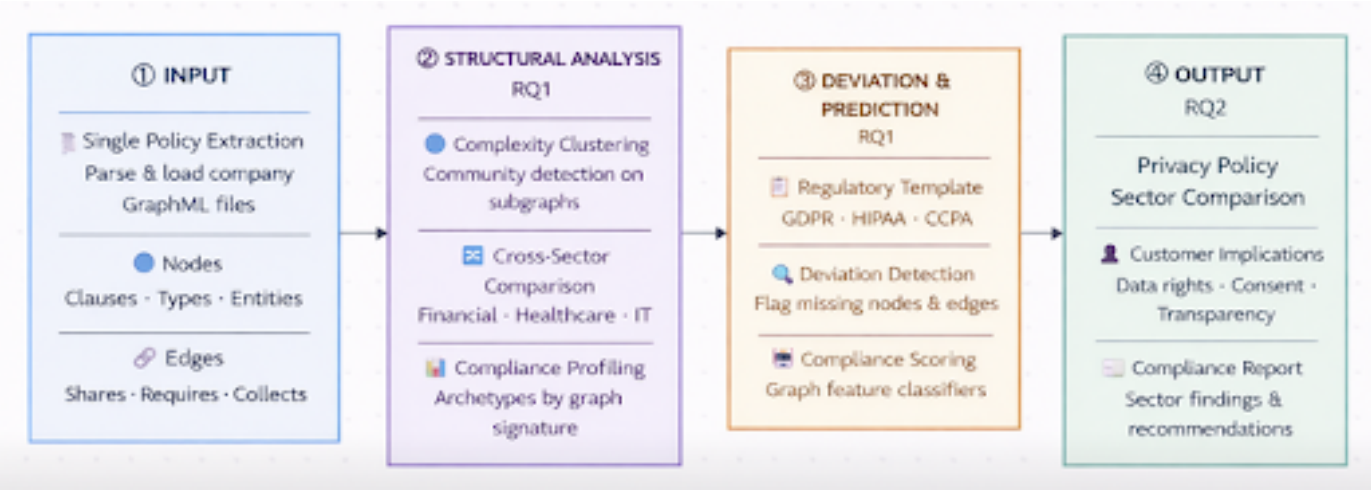

Fig. 2. Updated Proposed four-stage knowledge graph framework for privacy policy compliance analysis.

and clustering techniques to make complex policy structures interpretable [1], [2].

Joshi et al. [10] A key finding and contribution is that privacy policy data scraped from the web can be converted to a machine processable format. This issue must be addressed for our study. Other contributions are the real-time identification and mapping from threat to control for potential real-time mitigation.

Current research leaves critical questions unanswered. Existing tools are able to assess individual privacy policies [1], [2], [8], but they are unable to compare the differences in compliance between the IT, healthcare, and financial sectors or identify patterns peculiar to them (RQ1). However, PrivComp-KG and GraphDPR does show promise in this area with its sector mapping [11] [9]. Moreover, no study looks at how these compliance discrepancies actually effect customers in real-world situations, particularly how policy variances impact transparency, user rights accessibility, and data protection capability (RQ2). While Ramasamy et al. [2] applied clustering to individual apps, no work investigates whether structural analysis can reveal meaningful compliance patterns across entire industries, such as identifying ”privacy-protective” versus ”minimally compliant” industry groups. Additionally, no framework currently employs predictive models to automatically identify policies that deviate from regulatory expectations or industry norms, limiting regulatory oversight capabilities. These gaps are compounded by small dataset limitations, with studies using only 55-100 policies from single domains [1], [2], insufficient for meaningful cross-industry pattern analysis. A large dataset was used in Joshi et al,, but it is based on actual policies, not regulations, and is not a modern dataset (post 2019). [10]

To address RQ1, we plan to build knowledge graphs from policies across financial, healthcare, and IT sectors and compare their data handling practices to reveal sector-specific patterns. For RQ2, we will translate these technical differences into practical customer impacts regarding data protection, user rights, and transparency. We plan to apply clustering techniques [2] to identify compliance patterns across industries. We will also train predictive models on regulatory frameworks (GDPR, HIPAA, CCPA) to automatically flag policy deviations and potential violations [3]. Our framework will combine knowledge graph construction [1], [8], structural clustering [2], and obfuscation detection [3] to enable cross-industry comparative analysis, helping users identify privacy-protective companies and supporting regulatory oversight.

References

[1] S. Barrett, V. Ramasamy, G. Dorai, and B. Boswell, “Navigating privacy policies with nlp and graph mining: Advancements in user-centric legal document analysis,” in *SoutheastCon 2025*, pp. 1013–1022, 2025.

[2] V. Ramasamy, S. Barett, G. Dorai, and J. Zumbach, “Unveiling privacy policy complexity: An exploratory study using graph mining, machine learning, and natural language processing,” in *2025 6th International Conference on Artificial Intelligence, Robotics and Control (AIRC)*, pp. 514–520, 2025.

[3] J. Yerby and I. Vaughn, “Deliberately confusing language in terms of service and privacy policy agreements,” *Issues in information systems.*, vol. 23, no. 2, pp. 138–149, 2022.

[4] U. D. of Health and H. Services, “Health information privacy,” in *HHS.gov*, 2024.

[5] S. of California; Department of Justice, “California consumer privacy act,” in *oag.ca.gov*, 2024.

[6] F. T. Commission, “How to comply with the privacy of consumer financial information rule of the gramm-leach-bliley act,” in *ftc.gov*, 1999.

[7] V. Belcheva, T. Ermakova, and B. Fabian, “Understanding website privacy policies—a longitudinal analysis using natural language processing,” *Information*, vol. 14, no. 11, 2023.

[8] H. Cui, R. Trimananda, A. Markopoulou, and S. Jordan, “PoliGraph: Automated privacy policy analysis using knowledge graphs,” in *32nd USENIX Security Symposium (USENIX Security 23)*, (Anaheim, CA), pp. 1037–1054, USENIX Association, Aug. 2023.

[9] H. Chowdhury, M. I. Morsalin, R. S. Azade, and V. Ramasamy, “Graphdpr: A privacy policy analysis framework using knowledge graphs and topic modeling.,” in *Social Networks Analysis and Mining - 17th International Conference, ASONAM 2025, Proceedings*, vol. 16322, pp. pp. 422–430, 2026.

[10] K. P. Joshi, L. Elluri, and A. Nagar, “An integrated knowledge graph to automate cloud data compliance,” *IEEE Access*, vol. 8, pp. 148541–148555, 2020.

[11] L. Garza, L. Elluri, A. Piplai, A. Kotal, D. Gupta, and A. Joshi, "Privcomp-kg: Leveraging kg and llm for compliance verification," in *2024 IEEE 6th International Conference on Trust, Privacy and Security in Intelligent Systems, and Applications (TPS-ISA)*, pp. 97–106, 2024.

[12] Z. Munn, J. Peters, Micah D. C. Stern, C. Tufanaru, A. McArthur, and E. Aromataris, "Systematic review or scoping review? guidance for authors when choosing between a systematic or scoping review approach," *BMC Medical Research Methodology*, vol. 18, no. 1, p. 143, 2018.